# Esercizio U2/S5/L1

**Introduzione**.....2
**Obiettivi**.....2
**Metodologia**.....3
Raccolta dati tramite CLI.....3
Raccolta dati tramite Google Dorking.....5
Automazione con Python.....9
Analisi tramite Intelligenza Artificiale.....10
**Risultati**.....12
Informazioni tecniche rilevate.....12
Valutazione della rilevanza.....12
Possibili rischi individuati.....12
**Conclusioni**.....13

# Introduzione

L'Open Source Intelligence (OSINT) rappresenta l'insieme delle tecniche di raccolta e analisi di informazioni ottenibili da fonti aperte. L'obiettivo di questo elaborato è documentare un processo completo di raccolta passiva di informazioni su un dominio pubblico (io ho utilizzato *linkedin.com*), usando strumenti di Kali Linux, script Python personalizzati e un modello di intelligenza artificiale per l'analisi automatizzata dei dati.

L'attività si inserisce nel contesto della sicurezza informatica, dove la fase di ricognizione è fondamentale per comprendere la superficie di attacco di un sistema o di un'organizzazione.

# Obiettivi

Gli obiettivi principali dell'attività sono:

1. **Raccogliere informazioni passive** sul dominio target tramite WHOIS, DNS e Google Dorking.
2. **Automatizzare la raccolta** mediante script Python.
3. **Analizzare i dati ottenuti** utilizzando un modello di intelligenza artificiale (Gemini).

# Metodologia

## Raccolta dati tramite CLI

Sono stati utilizzati i seguenti comandi:

`whois linkedin.com`

- → informazioni amministrative, registrar, date di registrazione, name server.

```
┌──(simone㉿simone)-[~]
└─$ whois linkedIn.com
   Domain Name: LINKEDIN.COM
   Registry Domain ID: 91818680_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.markmonitor.com
   Registrar URL: http://www.markmonitor.com
   Updated Date: 2025-10-01T12:53:37Z
   Creation Date: 2002-11-02T15:38:11Z
   Registry Expiry Date: 2026-11-02T15:38:11Z
   Registrar: MarkMonitor Inc.
   Registrar IANA ID: 292
   Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
   Registrar Abuse Contact Phone: +1.2086851750
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
   Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
   Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
   Name Server: DNS1.P09.NSONE.NET
   Name Server: DNS2.P09.NSONE.NET
   Name Server: DNS3.P09.NSONE.NET
   Name Server: DNS4.P09.NSONE.NET
   Name Server: NS1-42.AZURE-DNS.COM
   Name Server: NS2-42.AZURE-DNS.NET
   Name Server: NS3-42.AZURE-DNS.ORG
   Name Server: NS4-42.AZURE-DNS.INFO
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-04T14:16:35Z <<<
```

`nslookup linkedin.com`

- → risoluzione DNS e indirizzi IP.

`nslookup -type=MX linkedin.com`

- → server di posta.

`dig linkedin.com ANY`

- → record DNS avanzati (NS, AAAA, ecc.).

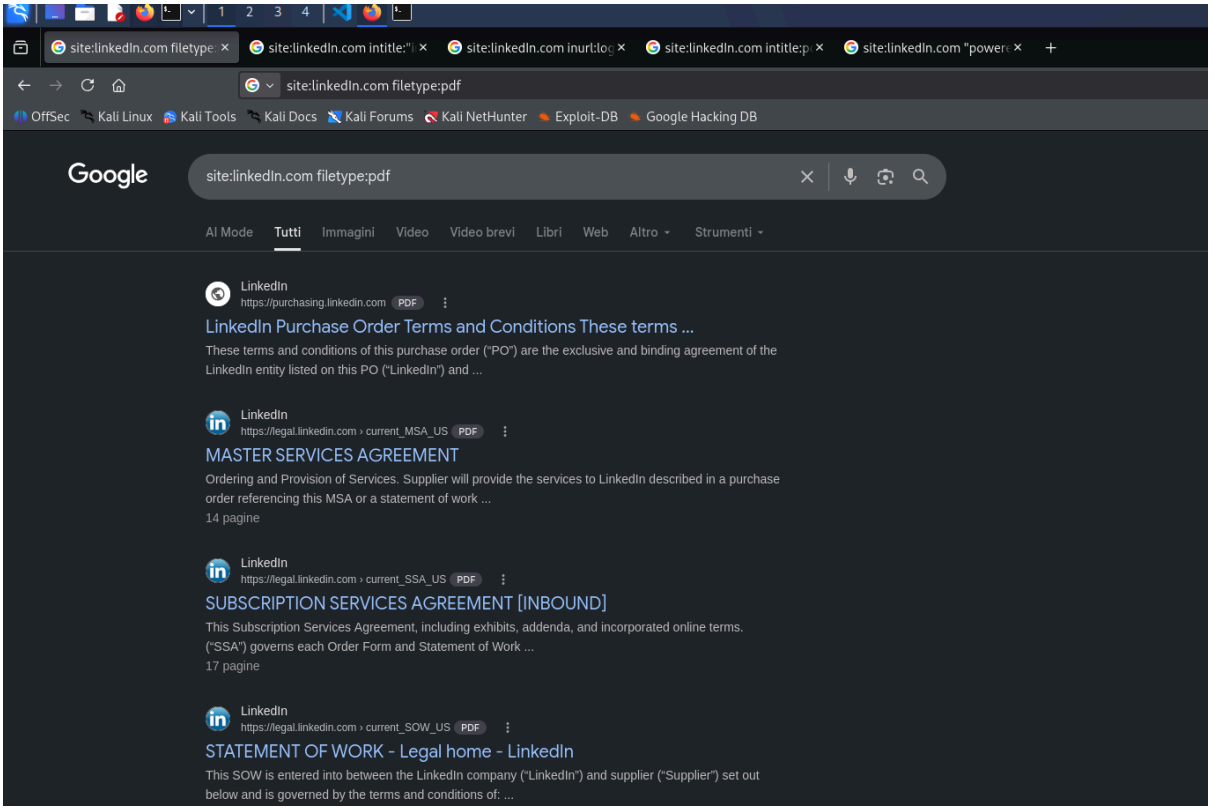
```
┌──(simone㉿simone)-[~]
└─$ nslookup linkedIn.com
Server:         192.168.1.1
Address:        192.168.1.1#53

Non-authoritative answer:
Name:   linkedIn.com
Address: 150.171.22.12
Name:   linkedIn.com
Address: 2620:1ec:50::12

┌──(simone㉿simone)-[~]
└─$ nslookup -type=MX linkedIn.com
Server:         192.168.1.1
Address:        192.168.1.1#53

Non-authoritative answer:
linkedIn.com    mail exchanger = 10 mail-d.linkedIn.com.
linkedIn.com    mail exchanger = 20 mail.linkedIn.com.
linkedIn.com    mail exchanger = 10 mail-a.linkedIn.com.
linkedIn.com    mail exchanger = 10 mail-c.linkedIn.com.

Authoritative answers can be found from:


┌──(simone㉿simone)-[~]
└─$ dig linkedIn.com ANY

; <<>> DiG 9.20.20-1-Debian <<>> linkedIn.com ANY
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 30591
;; flags: qr rd ra; QUERY: 1, ANSWER: 10, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: 9e9654c1d30954950100000069f8ab6efe0fb8a0fa7b7153 (good)
;; QUESTION SECTION:
;linkedIn.com.                  IN      ANY

;; ANSWER SECTION:
linkedIn.com.           280     IN      AAAA    2620:1ec:50::12
linkedIn.com.           106     IN      A       150.171.22.12
linkedIn.com.           44341   IN      NS      ns1-42.azure-dns.com.
linkedIn.com.           44341   IN      NS      ns4-42.azure-dns.info.
linkedIn.com.           44341   IN      NS      dns3.p09.nsone.net.
linkedIn.com.           44341   IN      NS      dns4.p09.nsone.net.
linkedIn.com.           44341   IN      NS      dns1.p09.nsone.net.
linkedIn.com.           44341   IN      NS      ns2-42.azure-dns.net.
linkedIn.com.           44341   IN      NS      ns3-42.azure-dns.org.
linkedIn.com.           44341   IN      NS      dns2.p09.nsone.net.

;; Query time: 20 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (TCP)
;; WHEN: Mon May 04 16:21:34 CEST 2026
;; MSG SIZE  rcvd: 339
```

Questi strumenti permettono una ricognizione passiva, senza generare traffico sospetto verso il dominio.

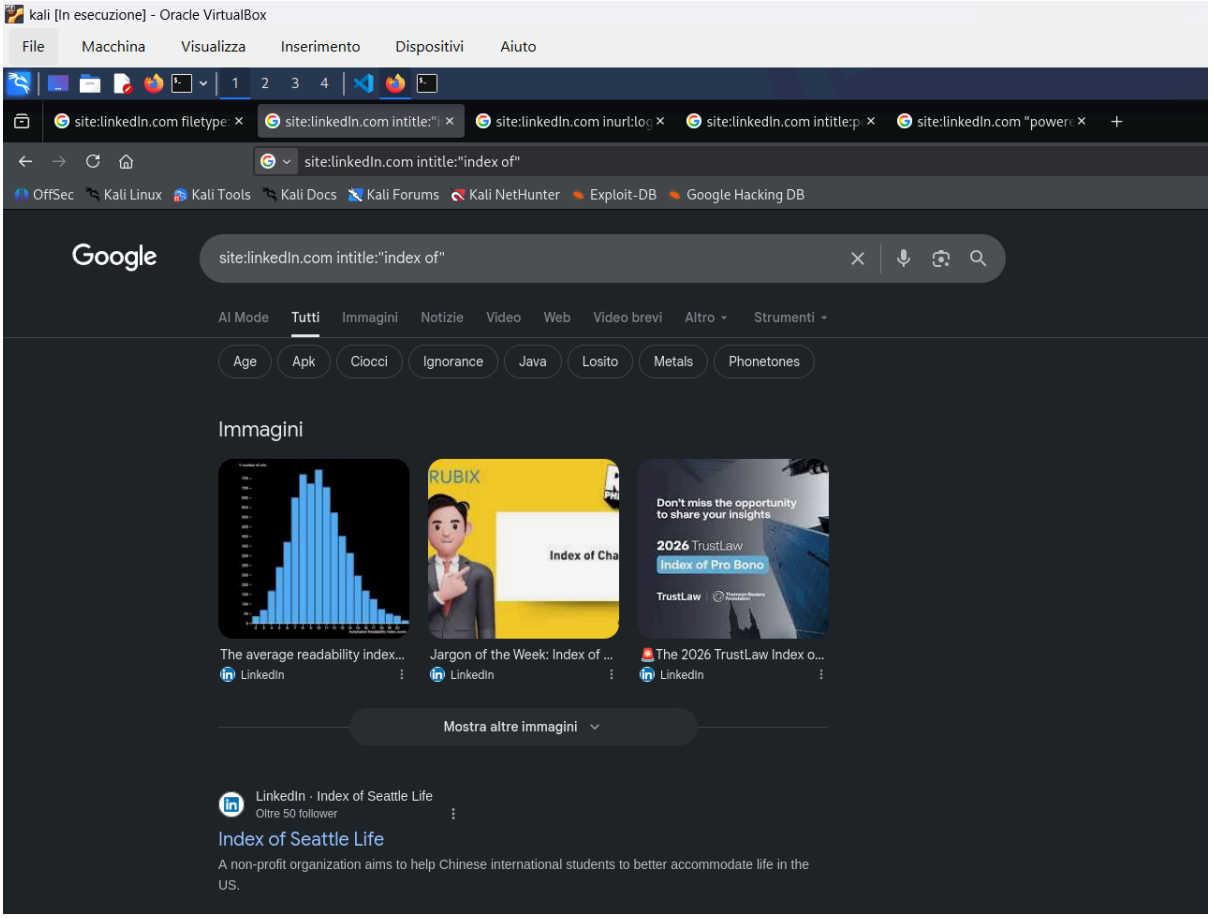
## Raccolta dati tramite Google Dorking

Sono state utilizzate query OSINT:

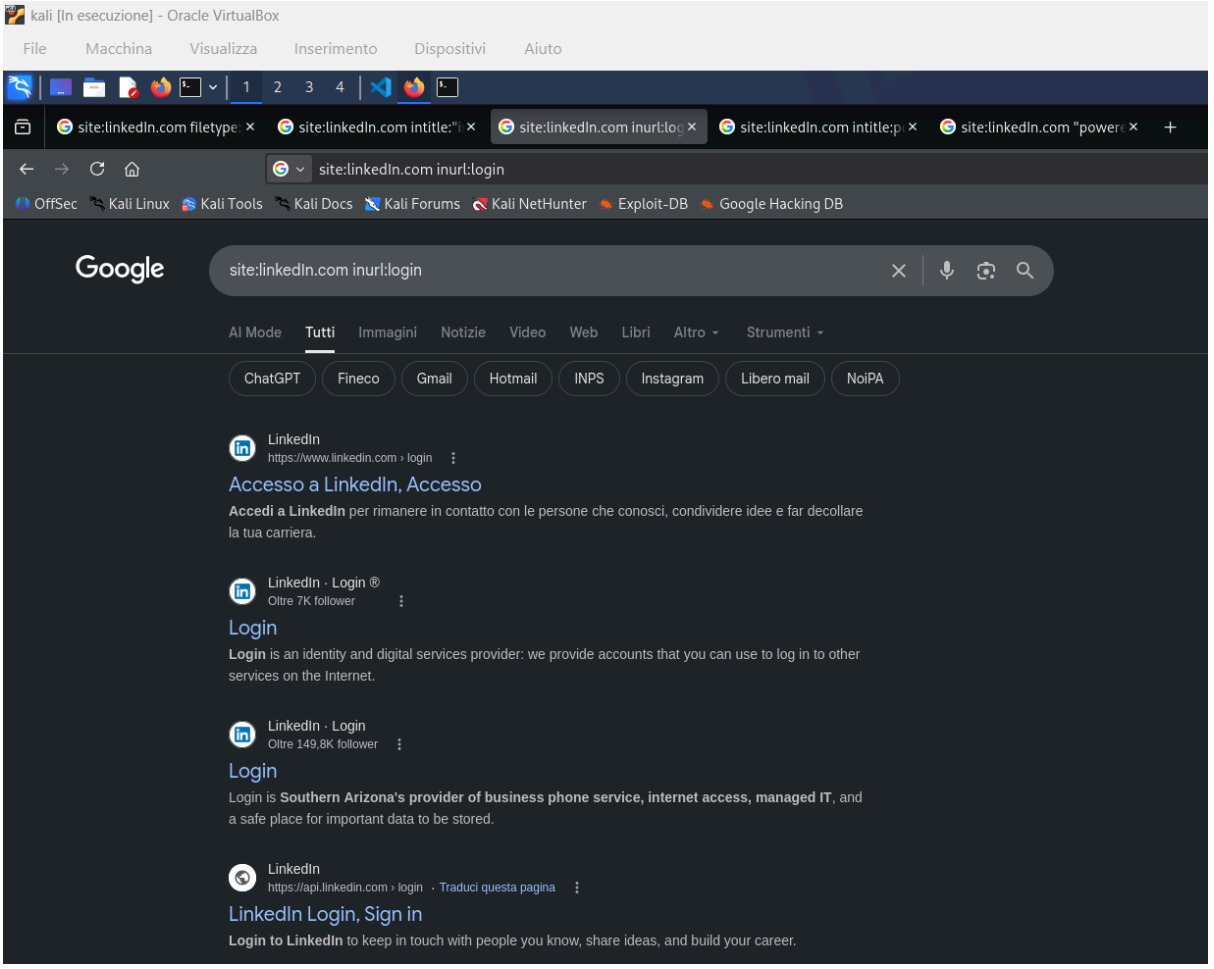
- `site:linkedin.com filetype:pdf`



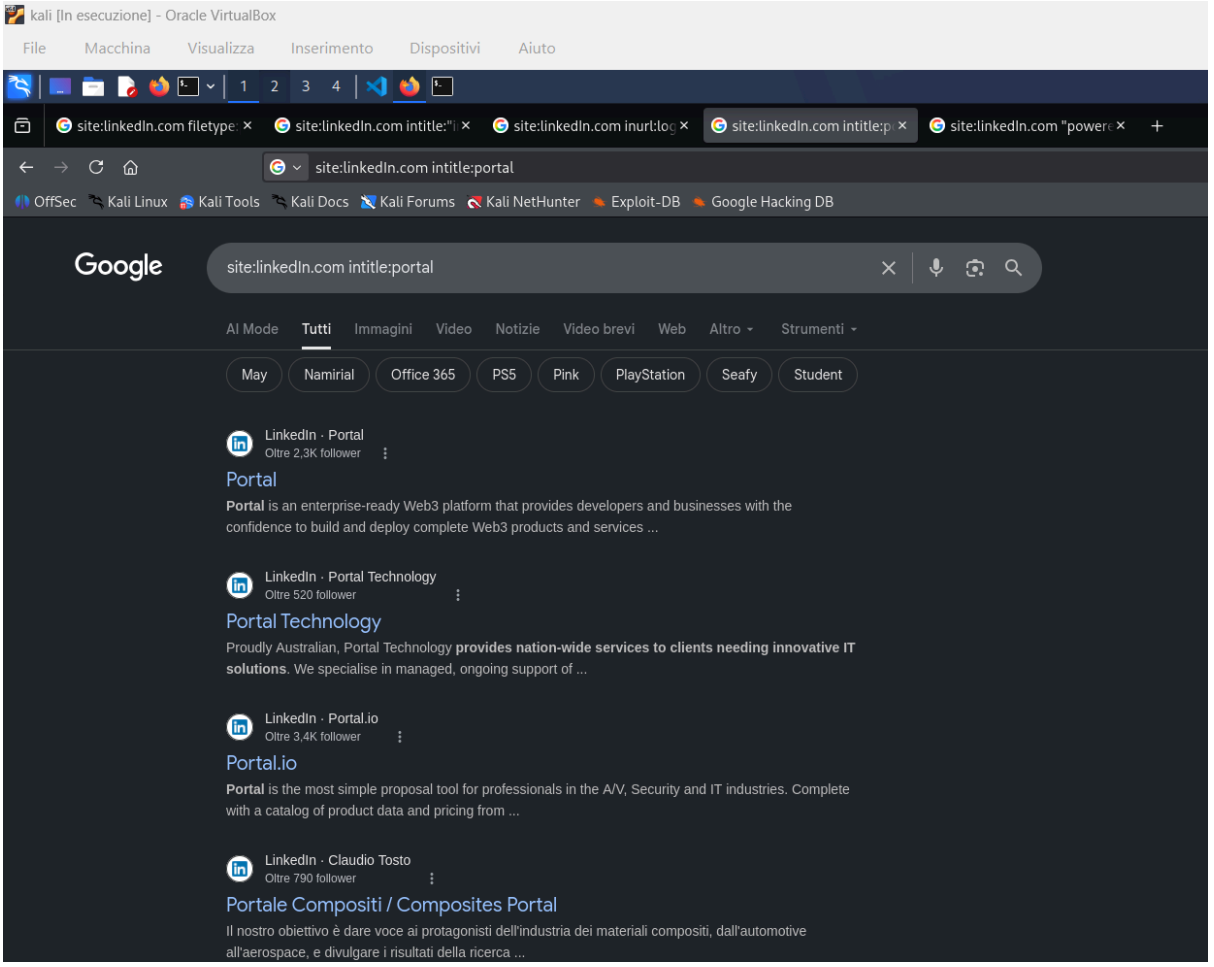
- `site:linkedin.com intitle:"index of"`



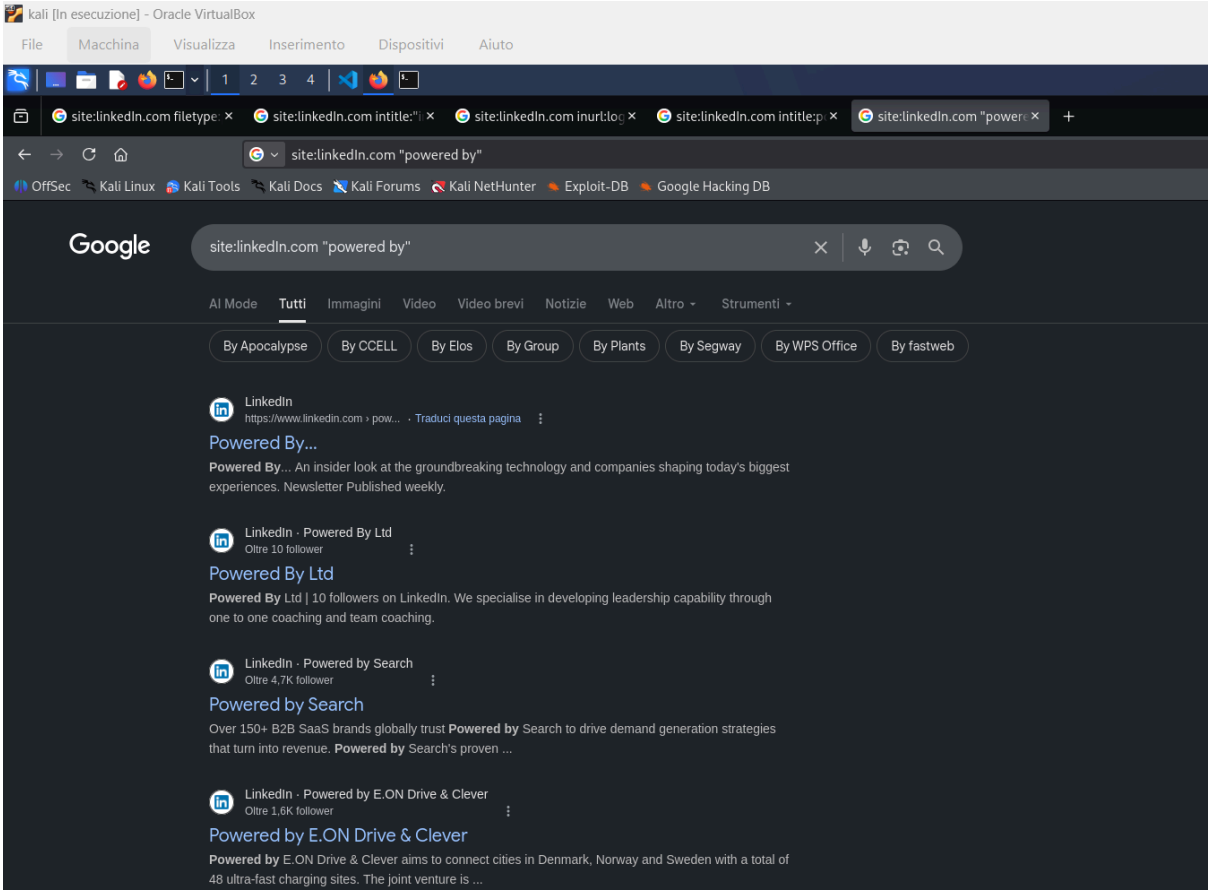
- `site:linkedin.com inurl:login`



- `site:linkedin.com intitle:portal`



- `site:linkedin.com "powered by"`



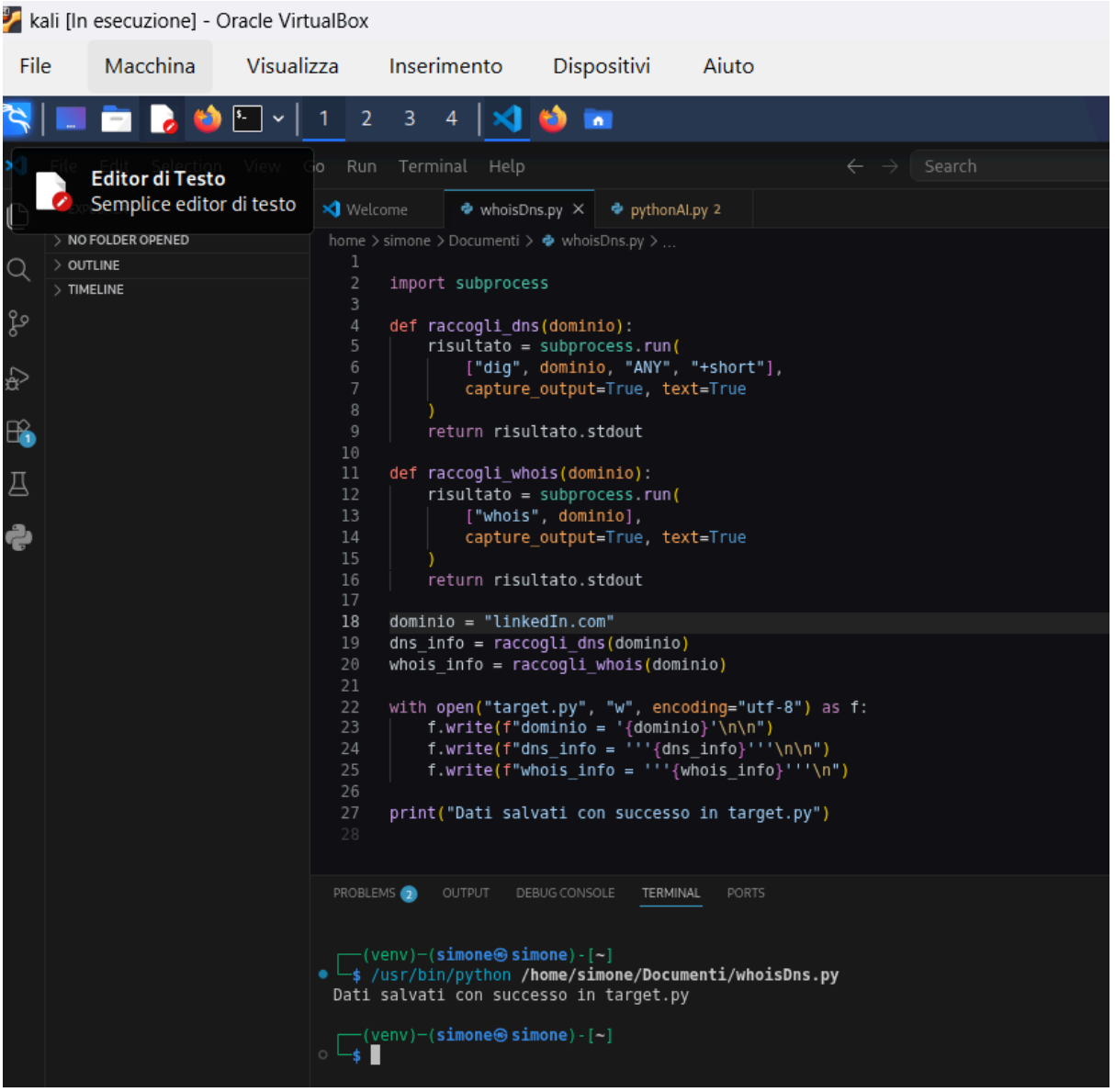

Queste ricerche consentono di individuare documenti pubblici, portali, pagine di login e informazioni tecniche utili per comprendere l'infrastruttura del dominio.

## Automazione con Python

È stato sviluppato uno script Python per automatizzare la raccolta di WHOIS e DNS:

- esecuzione di `dig` e `whois` tramite `subprocess`
- salvataggio dei risultati in un file `target.py`
- preparazione dei dati per l'analisi automatica

Successivamente, un secondo script ha inviato i dati raccolti a un modello AI per l'analisi strutturata.




## Analisi tramite Intelligenza Artificiale

Utilizzando la libreria `google-genai`, i dati raccolti sono stati analizzati da un modello LLM configurato per:

- non inventare informazioni
- classificare la rilevanza di sicurezza
- identificare possibili rischi
- restituire una tabella Markdown

L'output è stato salvato in un file `report.md`.

kali [In esecuzione] - Oracle VirtualBox

File Macchina Visualizza Inserimento Dispositivi Aiuto

File Edit Selection View Go Run Terminal Help

Welcome | whoisDns.py | pythonAI.py 2

home > simone > Documenti > pythonAI.py > ...

```python

from google import genai
from google.genai import types
import os
import target

client = genai.Client(api_key=os.environ["GEMINI_API_KEY"])

dati_osint = f"""
DOMINIO: {target.dominio}

DNS RECORDS:
{target.dns_info}

WHOIS (estratto):
{target.whois_info[:1000]}
"""

config = types.GenerateContentConfig(
    system_instruction="""
        Sei un analista OSINT esperto.
        Analizza SOLO le informazioni fornite, non inventare dati.
        Se un'informazione non è presente, scrivi 'Non disponibile'.
    """,
    temperature=0.2
)

prompt = f"""
Analizza i seguenti dati OSINT raccolti su un target.

Per ogni dato identificato, indica:
1. Informazione trovata
2. Rilevanza per la sicurezza (alta/media/bassa)
3. Possibili rischi

Dati:
{dati_osint}

Rispondi in formato tabella Markdown.
"""

response = client.models.generate_content(
    model="gemini-flash-latest",
    contents=prompt,
    config=config
)

print(response.text)
```

# Risultati

```
┌──(venv_ai)─(simone㉿simone)-[~]
└─$ python pythonAI.py

Ecco l'analisi OSINT dei dati forniti, organizzata secondo i criteri richiesti.

| Informazione trovata | Rilevanza per la sicurezza | Possibili rischi |
| :--- | :--- | :--- |
| **Indirizzi IP (IPv4: 150.171.22.12, IPv6: 2620:1ec:50::12)** | Media | Identificazione dei punti di terminazione della rete. Possibili bersagli per attacchi DDoS o scansioni di vulnerabilità dirette agli endpoint. |
| **Infrastruttura DNS (NSone e Azure DNS)** | Media | L'uso di provider multipli (Azure e NSone) indica ridondanza. Il rischio principale è il DNS Hijacking o attacchi DDoS mirati ai resolver per rendere il dominio irrag
giungibile. |
| **Registrar: MarkMonitor Inc.** | Bassa | MarkMonitor è un registrar specializzato nella protezione di brand aziendali. Indica un elevato standard di protezione contro il furto di domini. |
| **Stati del dominio: client/serverDeleteProhibited, client/serverTransferProhibited, client/serverUpdateProhibited** | Alta (Positiva) | Questi "Registry Locks" impediscono trasferimenti, modifiche o cancellazioni non a
utorizzate. Il rischio di Domain Hijacking è drasticamente ridotto. |
| **Data di scadenza: 2026-11-02** | Bassa | La scadenza a lungo termine previene il rischio di "domain dropping" (scadenza accidentale del dominio e acquisto da parte di terzi). |
| **Data di creazione: 2002-11-02** | Bassa | Indica un dominio storico e consolidato. Utile per analisi di reputazione, ma non presenta rischi tecnici immediati. |
| **Contatti Abuse (Email e Telefono)** | Bassa | Informazioni pubbliche per segnalare attività illecite. Possono essere usate per tentativi di social engineering verso il supporto del registrar. |
| **Dati dell'intestatario (Registrant)** | Non disponibile | Non sono presenti dati personali o aziendali specifici nell'estratto WHOIS fornito. |
| **Record MX (Mail Server)** | Non disponibile | Non è possibile valutare la sicurezza della posta elettronica (es. SPF, DKIM, DMARC) dai dati forniti. |
| **Sottodomini** | Non disponibile | Non sono presenti informazioni su eventuali sottodomini che potrebbero ampliare la superficie di attacco. |
```

L'analisi AI ha evidenziato i seguenti punti principali:

## Informazioni tecniche rilevate

- **Indirizzi IP** (IPv4 e IPv6) del dominio.
- **Infrastruttura DNS** basata su Azure DNS e Nsone.
- **Registrar**: MarkMonitor Inc., specializzato nella protezione dei brand.
- **Stati del dominio**: numerosi flag di protezione (client/serverDeleteProhibited, UpdateProhibited, TransferProhibited).
- **Date di creazione e scadenza** del dominio.
- **Contatti abuse** del registrar.

## Valutazione della rilevanza

- **Alta**: registry lock e protezioni del dominio.
- **Media**: infrastruttura DNS e indirizzi IP pubblici.
- **Bassa**: dati amministrativi e date di registrazione.
- **Non disponibile**: sottodomini, record MX completi, configurazioni SPF/DKIM/DMARC.

## Possibili rischi individuati

- Possibili attacchi DDoS sugli endpoint IP.
- Tentativi di social engineering verso i contatti abuse.
- DNS hijacking (rischio mitigato dalla presenza di registry lock).
- Scarsa visibilità su eventuali sottodomini esposti.

# Conclusioni

L’attività svolta ha permesso di realizzare un processo completo di raccolta e analisi OSINT in modalità passiva, integrando strumenti di sistema, automazione Python e intelligenza artificiale.

I risultati mostrano che il dominio *linkedin.com* presenta un elevato livello di protezione amministrativa e infrastrutturale, con rischi limitati principalmente agli aspetti di esposizione pubblica degli endpoint IP e potenziali tentativi di social engineering.